

Advanced Threat Detection and Hunting



Advanced Threat Detection and Hunting

- Advanced Threat Detection Techniques
- Proactive Threat Hunting Strategies

Labs

- Hands-on Lab: Conducting Threat Hunts



Advanced Threat Detection Techniques

- Advanced Threat Detection Techniques are methods used to identify stealthy, sophisticated, and evasive attacks that bypass traditional signature-based security controls.
- These techniques focus on **behavior**, **context**, **correlation**, and **intelligence**, rather than known malware patterns, like:
 - **Behavioural-Based Detection** - Detects malicious activity based on *what an entity does*
 - **Machine Learning and Anomaly Detection** - Uses ML models trained on *baseline normal behavior* to detect deviations
 - **Threat Intelligence–Driven Detection** - Uses global and local *threat intelligence feeds* to identify known malicious indicators and behaviors.
 - **Attack Chain and Kill Chain Correlation** - Detects threats by correlating *multiple low-severity events* into a high-confidence incident.



Advanced Threat Detection Techniques

- From a Microsoft EDR engineering perspective, advanced threat detection is not signature-based antivirus. It is telemetry-driven behavioural analytics across endpoints, identities, email, and cloud workloads using:
 - Endpoint telemetry (process, registry, network, file, memory)
 - Identity signals (Kerberos, NTLM, lateral movement)
 - Cloud app activity
 - Threat intelligence correlation
 - Machine learning + behavioural modelling
- Primarily implemented through:
 - Microsoft Defender for Endpoint
 - Microsoft Defender XDR
 - Microsoft Sentinel



Behavioural Analytics (Post-Signature Detection)

- Instead of detecting “known malware hash,” EDR monitors abnormal behavior patterns.
- **Examples**
 - winword.exe spawning powershell.exe
 - lsass.exe memory access attempts
 - Encoded PowerShell command execution
 - Office → child process → network beacon



Implementing Behavioural Analytics

- Enable EDR in block mode
- Enable cloud-delivered protection
- Use Attack Surface Reduction (ASR) rules
- Review:
 - DeviceProcessEvents
 - DeviceNetworkEvents
 - DeviceRegistryEvents

- **Why it matters**

- Detects:
 - Zero-day exploits
 - Fileless malware
 - Living-off-the-Land (LotL) attacks

MITRE ATT&CK Mapping & Detection Engineering

- Microsoft maps detections to MITRE tactics:
 - Initial Access
 - Execution
 - Persistence
 - Privilege Escalation
 - Defense Evasion
 - Credential Access
 - Lateral Movement
 - Command & Control
 - Exfiltration

Practical Technique

Use Advanced Hunting:

```
DeviceProcessEvents  
| where ProcessCommandLine contains "EncodedCommand"
```

Map findings to ATT&CK technique (e.g., T1059 – Command and Scripting Interpreter).



Memory-Based & Credential Theft Detection

- **Detection Focus**

- LSASS access attempts
- Mimikatz patterns
- Token manipulation
- Suspicious handle requests

Example:

```
DeviceProcessEvents  
| where InitiatingProcessFileName != "lsass.exe"  
| where ProcessCommandLine contains "lsass"
```

- Enable:
 - Credential Guard
 - ASR rule: Block credential stealing from LSASS



Lateral Movement Detection

- Advanced detection monitors:

- SMB admin shares
- Pass-the-Hash
- RDP brute force
- WMI remote execution
- PsExec patterns

- Hunt for suspicious RDP

```
DeviceLogonEvents  
| where LogonType == "RemoteInteractive"  
| summarize count() by AccountName, DeviceName
```

- Correlate with unusual source IPs.



Threat Intelligence Integration

- Microsoft correlates:
 - IP reputation
 - Domain reputation
 - Known C2 infrastructure
 - IOC feeds
- Enabled via:
 - Cloud protection
 - TI indicators in Defender
 - Integration with Microsoft Sentinel for custom threat feeds



Automated Investigation & Remediation (AIR)

- Built into Microsoft Defender for Endpoint
- Capabilities:
 - Automatically analyses alerts
 - Builds process trees
 - Determines root cause
 - Quarantines malicious files
 - Isolates devices
- Enterprise best practice:
 - Semi-automated for Tier 1 SOC
 - Fully automated in high-confidence scenarios



Anomaly-Based Detection (ML Driven)

- Examples:
 - Unusual login time patterns
 - Rare process execution
 - New service creation
 - Suspicious scheduled task
- Microsoft uses:
 - User & Entity Behavioural Analytics (UEBA)
 - UEBA is a cybersecurity approach that utilizes machine learning and data analytics to establish normal behavioral baselines for users, devices, and applications
 - Cross-tenant threat signals
 - AI-driven anomaly detection



Advanced Threat Hunting (Proactive Detection)

- Hunt for encoded PowerShell

```
DeviceProcessEvents  
| where FileName == "powershell.exe"  
| where ProcessCommandLine contains "-enc"
```

- Hunt for rare processes

```
DeviceProcessEvents  
| summarize count() by FileName  
| order by count_ asc
```

Rare processes often indicate targeted attacks.



Endpoint Isolation & Live Response

- From Defender portal:
 - Isolate machine (full or selective)
 - Collect forensic package
 - Run live response commands
 - Dump memory
 - Kill processes remotely
- This is critical for:
 - Ransomware containment
 - Active C2 disruption



Ransomware Detection Techniques

- Microsoft detects:
 - Mass file modification
 - Entropy spikes
 - Shadow copy deletion
 - Suspicious encryption patterns
- Hunting example:

```
DeviceFileEvents  
| summarize count() by InitiatingProcessFileName  
| order by count_ desc
```



Cross-Domain Correlation (XDR Level)

- Used in Microsoft Defender XDR.
- Correlates:
 - Email phishing → malicious link click → endpoint payload → lateral movement → data exfiltration
- This dramatically reduces alert fatigue and improves detection fidelity.

Other Advanced Threat Detection Techniques

- **Living-off-the-Land (LotL) Detection** - Identifies abuse of *legitimate system tools* used maliciously.
- **Identity and Credential Abuse Detection** - Detects misuse of credentials and identity-based attacks.
- **Network Behavior and C2 Detection** - Identifies suspicious outbound communication patterns.
- **Advanced Threat Hunting** - Proactive detection using hypothesis-driven investigation
- **Automated Investigation and Response (AIR)** - Uses automation to validate and respond to detected threats.
- **Deception and Signal-Based Detection** - Uses decoys and high-fidelity signals to detect attackers early.



Proactive Threat Hunting Strategies

- Proactive threat hunting is **hypothesis-driven investigation** using endpoint, identity, and cloud telemetry to uncover stealthy adversary activity that bypasses preventive controls.
- Unlike reactive alert handling, **threat hunting assumes the attacker may already be inside and seeks evidence before impact occurs.**
- Core Principles of Proactive Threat Hunting:
 - Assume compromise
 - Focus on behavior, not alerts
 - Use intelligence, context, and baselines
 - Validate hypotheses with evidence
 - Continuously improve detections



Proactive Threat Hunting platforms:

- Microsoft Defender for Endpoint
- Microsoft Defender XDR
- Microsoft Sentinel

Threat Hunting Methodologies

- **Hypothesis-Driven Hunting**

- Form a hypothesis based on known attacker techniques.
- Example hypothesis – “An attacker may be using PowerShell for credential access.”

- **Intelligence-Led Hunting**

- Use external and internal threat intelligence.
- Example – Hunt for behaviors used by a specific ransomware group

- **Baseline Deviation Hunting**

- Identify deviations from normal behavior.
- Example – Rare processes on endpoints



Key Threat Hunting Domains

▪ **Endpoint Hunting**

- Suspicious PowerShell usage
- Abnormal parent-child process chains
- Persistence mechanisms

▪ **Identity Hunting**

- Privilege escalation
- Lateral logins
- Token misuse

▪ **Network Hunting**

- Beaconing patterns
- DNS tunnelling
- Suspicious outbound connections

▪ **Email & Initial Access**

- Phishing artifacts
- Malicious attachments
- URL-based attacks

Establishing a structured Hunting Framework

Professional hunting follows this lifecycle:

1. Define Hypothesis

- Example: “An attacker is using encoded PowerShell for execution.”

2. Identify Relevant Telemetry

- DeviceProcessEvents
- DeviceNetworkEvents
- DeviceLogonEvents

3. Hunt via KQL

4. Analyze & Pivot

5. Document Findings

6. Convert to Detection Rule (if validated)

This converts hunting into detection engineering maturity.

Threat-Informed Hunting (MITRE-Based)

- Map hunts to tactics such as:

- Initial Access
- Credential Access
- Lateral Movement
- Persistence
- Defense Evasion

- Example hypothesis:

- Attackers attempt credential dumping via LSASS memory access.

```
DeviceProcessEvents  
| where InitiatingProcessFileName != "lsass.exe"  
| where ProcessCommandLine contains "lsass"
```


Behaviour-Based Hunting (Not IOC-Based)

- Avoid relying solely on:
 - Hash
 - IP
 - Domain
- Focus on anomalous patterns
- Example: Office spawning PowerShell

```
DeviceProcessEvents  
| where InitiatingProcessFileName in ("winword.exe","excel.exe","outlook.exe")  
| where FileName == "powershell.exe"
```



Rare Event & Outlier Hunting

- Attackers often trigger “rare” activity.
- Focus on:
 - Low-frequency executables
 - Unusual scheduled tasks
 - Newly created services

```
DeviceProcessEvents  
| summarize count() by FileName  
| order by count_ asc
```



Lateral Movement Hunting

- Detect movement before ransomware stage.
- Abnormal RDP activity

```
DeviceLogonEvents  
| where LogonType == "RemoteInteractive"  
| summarize count() by AccountName, DeviceName
```

- Look for:
 - New admin account usage
 - Service accounts logging into workstations
 - Logins outside business hours



Persistence Mechanism Hunting

- Attackers create stealth persistence.
- Hunt for:
 - New scheduled tasks
 - Registry Run keys
 - Services

```
DeviceRegistryEvents  
| where RegistryKey contains "Run"
```

- Also monitor:
 - Startup folder modifications
 - WMI event subscriptions



Command & Control (C2) Hunting

- Detect beaconing behavior.
- Indicators:
 - Regular interval outbound traffic
 - Rare external domains
 - Non-browser processes making internet connections
- Focus on:
 - PowerShell
 - rundll32
 - wmic
 - Mshta (Microsoft HTML Application Host)

```
DeviceNetworkEvents  
| summarize count() by RemoteUrl, InitiatingProcessFileName  
| order by count_ asc
```



Identity-Based Hunting

- Using Defender XDR cross-domain signals.
- Hunt for:
 - Impossible travel
 - MFA fatigue attacks
 - Privileged account anomalies
 - NTLM fallback attempts
- Combine:
 - DeviceLogonEvents
 - IdentityLogonEvents



Ransomware Pre-Encryption Detection

- Before encryption starts, attackers:
 - Disable backups
 - Delete shadow copies
 - Modify GPO
 - Escalate privileges
- Hunt for shadow copy deletion

```
DeviceProcessEvents
```

```
| where ProcessCommandLine contains "vssadmin delete shadows"
```



Living-Off-the-Land (LotL) Hunting

- Focus on native binaries:

- powershell.exe
- cmd.exe
- wmic.exe
- certutil.exe
- mshta.exe
- rundll32.exe

```
DeviceProcessEvents  
| where FileName == "certutil.exe"
```

- Look for:

- Download behavior
- Base64 decoding
- Suspicious arguments

Automation-Assisted Hunting

- Use:
 - Custom detection rules
 - Scheduled KQL queries
 - Watchlists
 - SOAR playbooks in Sentinel
- Mature SOCs:
 - Convert validated hunts into production detections
 - Track false positive rate
 - Maintain detection coverage matrix



Advanced Hunting Playbook (Enterprise Model)

- Weekly Routine:
 - Credential theft hunt
 - Lateral movement hunt
 - Rare process hunt
 - Privileged account audit
 - C2 beacon analysis
- Monthly:
 - ATT&CK coverage review
 - Detection gap analysis
 - Telemetry health validation







That's all Folks!